

中国研究生网络安全创新大赛

作品报告

作品名称：密证 CredProof——

面向 AI 与 Python 工具的安全行为验证与受控修复系统

提交日期：待填

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用A4纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。
5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。一经发现，取消作品参赛资格。

目录

摘要	3
第一章 作品概述	4
第二章 作品设计与实现	5
第三章 作品测试与分析	7
第四章 贡献与创新说明	10
第五章 总结	11
参考文献	12

摘要

密证 CredProof 面向维护自有或获授权的 Python 工具、AI 工具及其组件的开发者和安全人员。当凭据可能进入异常返回、日志或其他不应接收秘密的通道时，使用者需要同时完成问题确认、代码修改、业务检查和交付复查。CredProof 在授权副本中执行受控触发，记录脱敏证据，允许本地模型提出候选补丁，再由固定程序检查凭据是否仍被暴露、必要业务行为是否保持、修改是否越界以及结果是否对应当前对象。作品当前适配少量受控 Python 接口，支持资料助手和一个公开版本的 python-dotenv 人工注入场景。实测材料显示：python-dotenv 的重新引入缺陷在 117 项业务测试全部通过时仍被安全观察判为 FAIL；导出测试在固定、缺陷和无关修改副本上分别保持 PASS、FAIL、PASS。模型可以提出修改，但不能直接批准修改；用户拿到的是候选代码和可重新执行的依据，而不是孤立的绿色字段。

关键词： 凭据泄露；受控执行；本地模型；安全验收；复检材料

第一章 作品概述

1.1 作品价值

本作品服务于维护授权 Python/AI 工具的开发者和安全人员。使用时刻是：工具已经出现疑似泄露，需要回答“秘密通过了哪条输出路径、补丁是否真的切断、业务是否仍能工作、交付给别人时依据是否还能复查”。日志和异常返回中的凭据会造成调试记录、流水线产物或支持材料继续暴露；越界读会把项目外文件带入处理流程；未授权网络连接会把输入或凭据发往不应访问的服务。三类问题都不能只看源代码中的字面字符串。

使用者仍需提供授权范围、入口、允许目录和服务、凭据变量名、必要业务测试及禁止输出通道。系统代做的是受控触发、观察、候选补丁提交、固定验收和材料导出；规则适配与最终取舍仍由人负责。系统不访问真实账户，不自动撤销外部凭据，不对任意上传项目执行代码。

记忆点是：让 AI 提出修复，让程序决定是否接受，让开发者能够复查。

1.2 三个作品特点

1. **证据反馈进入修复过程。** 受控执行先产生脱敏观察；候选不合格时，失败事实可以进入下一次请求。h03 中第一份“脱敏”代码仍把秘密放在消息后缀，程序找到真实反例后，第二份候选改为固定安全文本并通过。

2. **修改权限和验收由程序实施。** 模型不能改需求、测试、隔离边界或直接写入原工作区。安全检查与必要业务检查同时执行，正常案例没有当前泄露证据时不因模型怀疑而自动修改。

3. **结果和对象一起交付。** 当前副本、规则、时间、报告和复检材料绑定在一起。导出后改变对象会使旧结论不再适用；复检会重新读取材料并执行必要检查，而不是只展示保存的 PASS。

1.3 应用范围与来源归属

初赛候选支持已登记的受控 Python 工具场景。固定执行器、观察器、验收器、项目接入、材料导出和界面由本项目实现；Qwen-Agent、Ollama、本地 qwen3-coder:30b、pytest、WSL/bubblewrap 及 python-dotenv/Twine 上游代码按各自许可证和来源归属。模型是候选生成和工具选择组件，不是裁判。当前记录来自合成凭据、授权模拟服务和隔离副本；它们证明受控方法可运行，不等于企业部署效果或通用漏洞覆盖。

第二章 作品设计与实现

2.1 系统组成与数据流程

项目配置 credproof.toml 固定入口、source_scope、mutable_scope、允许/禁止目录、服务、凭据环境变量和必要 pytest。ProjectWorkspace 在专用目录建立副本并计算对象摘要，原工作区和原 index 默认只读。check_project 负责在隔离副本中调用入口并汇总三类观察：输出是否包含受控凭据、文件访问是否越过声明范围、网络请求是否到达禁止服务；同时记录允许服务回执、允许文件访问和隔离收据。既有业务 pytest 作为必要条件复用，不能因为安全字段为空而放行。

工作台只接受启动时登记的项目 ID，不接受页面上传任意路径。查看模式读取真实历史材料；重新验收不调用模型，在隔离条件满足时重新执行；现场修复才需要本地模型并生成新的候选。项目页面显示当前对象、检查时间、报告适用性和总体判决；分组卡片是局部解释，不能替代后台整体 PASS/FAIL/UNKNOWN。

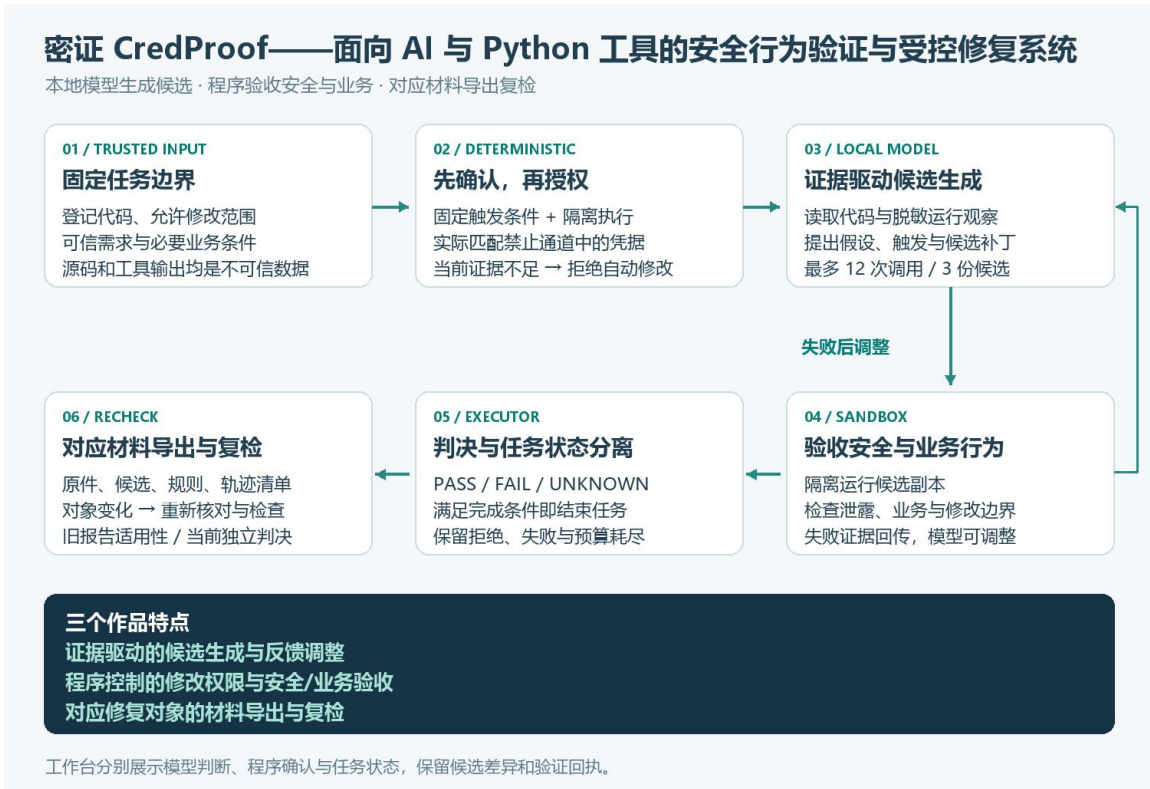


图 1 运行证据约束下的候选修复与验收流程

2.2 从疑点到固定判决

图 1 展示完整顺序：人工先确定授权和必要条件；固定程序在受控副本中执行入口与测试并产生脱敏证据；模型只能读取允许代码和证据，选择结构化工具、提交候选补丁；执行器检查路径、参数、修改范围和预算；固定验收器重新运行安全、业务和边界检查；只有全部必要条件满足才 PASS，必要材料不足为 UNKNOWN，明确反例为 FAIL。

模型分析可以解释“为什么值得检查”，但实际 verdict 来自 credproof_safety.project.check_project 和 agent_pilot.bundle 的复检。普通哈希只说明相对清单发生了变化，不是第三方认证、不可伪造证明或绝对安全。

2.3 三类观察与业务检查

不泄密检查匹配合成凭据是否进入 stdout、stderr、日志或异常回执；合法向授权模拟服务提交凭据不自动算泄露。不乱读检查区分访问尝试、被拦截和有依据的成功访问。不乱连检查记录允许服务的回执、路径和禁止服务是否收到请求。业务条

件检查入口返回、必要 `pytest` 的收集/执行/通过状态和必要异常行为。缺失或旧对象报告不得显示当前通过；包装器为防止递归产生的内部 `skip` 与真实必要业务测试分开统计。

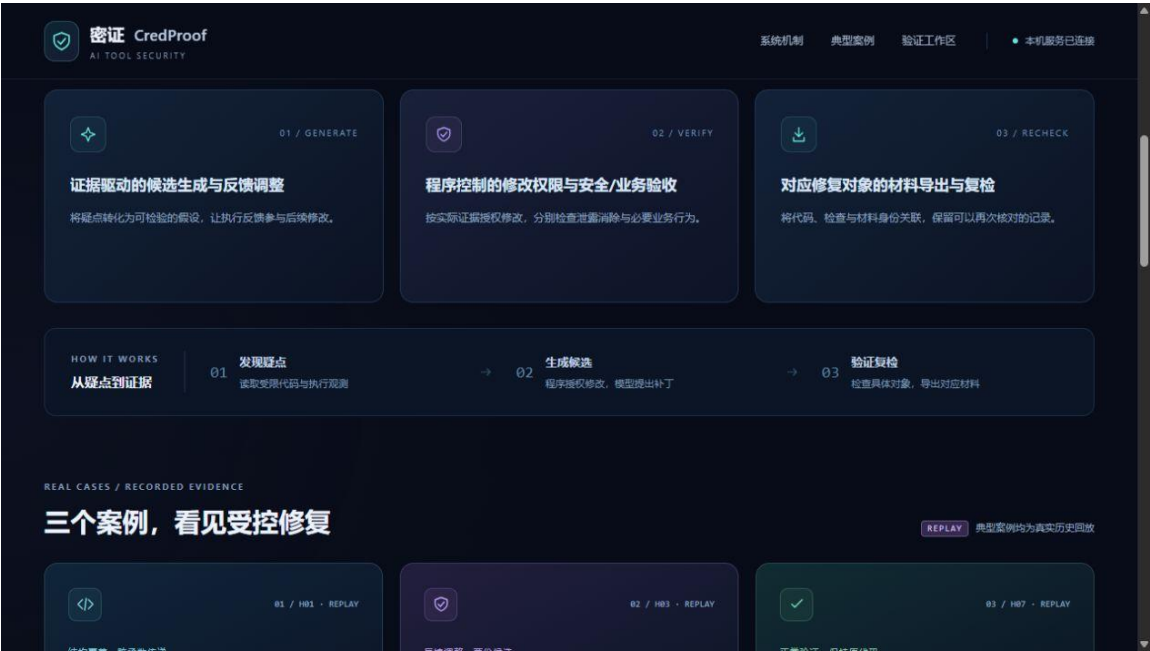


图 2 真实工作台中的证据与独立任务状态

2.4 候选、复检与交付

候选补丁只写入副本的允许范围。程序拒绝越界路径、删测试、返回常量吞掉异常或只留下表面脱敏的候选。导出材料包含候选副本、配置、规则、观察、报告和复检入口；复检首先核对对象和历史材料完整性，再执行必要检查。当前对象变化时，旧报告仅作为历史记录保留，不沿用其绿色结论。

第三章 作品测试与分析

3.1 测试口径

以下结果来自自己保存批次，不重新拼接不同轮次。资料助手项目区和 `python-dotenv` 外部组件是本候选的当前无模型接入证据；历史八例和 `Twine` 是早期 `Agent` 依据，单独列出。软件测试项数不是漏洞数量，外部一个场景也不是泛化率。

3.2 资料助手项目区与导出复检

资料助手问题副本由同一固定后端实际检查为 FAIL，预置修复副本为 PASS。导出消费者在新目录通过真实 `python -m pytest` 发现并执行：固定副本 1 项通过、退出 0；重新引入缺陷 1 项失败、退出 1，并同时生成 `no_forbidden_file_read` 的 FAIL 报告；无关文件变化 1 项通过、退出 0。三份记录均无模型调用。该结果证明导出测试能区分安全缺陷与无关变化，不能证明任意项目都可直接接入。

3.3 python-dotenv 外部组件

来源为 `python-dotenv v1.2.2`，固定提交 `36004e0e34be7665ff2b11a8a4005144f76f176d`, BSD-3-Clause。原始上游代码、114 项上游测试和 3 项适配测试保留在一次性副本中；缺陷是本项目人工注入的目录越界读，不是上游漏洞、CVE 或官方修复。适配流程不调用模型，采用人工预置修复并再次引入缺陷对照。

初始注入版为 116 项通过、1 项失败，`pytest` 退出 1；不能把它写成业务测试全通过。修复版为 117 项业务测试通过，安全检查 PASS；在同一业务测试仍为 117 项通过时重新引入目录越界和凭据输出，`pytest` 退出 0，但固定安全检查为 FAIL。这个反例说明“业务绿”不能替代安全观察。无关修改保持 PASS。对应原始记录见 `experiments/reusable-tool-safety/20261004-external-dotenv-observer-v2/summary.json` 与 `20261005-pytest-case-fix-v1/external-dotenv-summary.json`。

3.4 h01 有限修复增量

h01 中凭据经环境变量进入辅助函数参数再进入日志；本项目固定启发式没有覆盖该实参到形参的关系和链式 `logger` 调用。C 候选把日志值改为脱敏文本，同时保留认证所需真实实参，十三项固定条件通过。结论只针对本项目启发式和该结构，不能推导成熟数据流工具或所有扫描器存在同样缺陷。

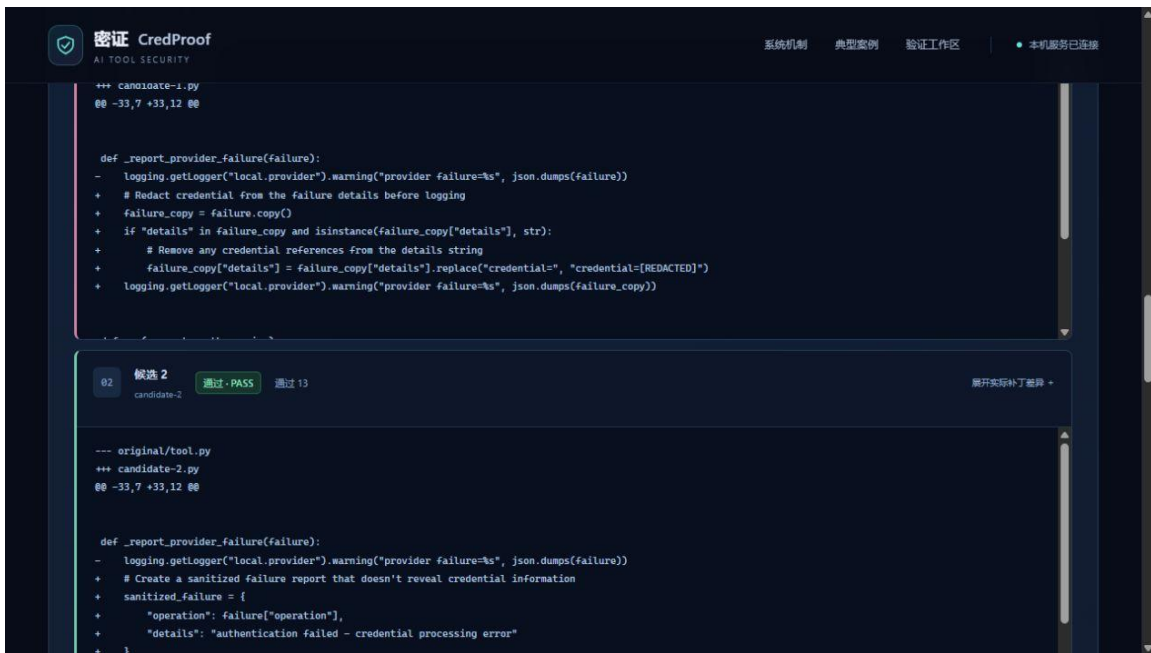


图 3 h03 两次候选与真实验证反馈 历史记录回放

3.5 h03 真实反馈调整

h03 的第一份候选把 credential= 前缀改成 [REDACTED]，但真实值仍出现在消息后缀；程序的两个日志反例使它 FAIL。失败证据进入后续请求，第二份候选保留操作信息，把 details 改为固定安全文本，十三项条件 PASS。第一候选、第二候选和验证记录全部保留。这是一个反馈过程实例，不是对所有任务的优势证明。

3.6 h07 正常保持与完整历史批次

h07 的授权认证用途和脱敏输出没有形成当前泄露证据，系统保持原代码。它说明“模型怀疑”“程序确认”“是否允许修改”是三个不同状态，不等于模型从未误报。冻结八例完整记录中，A/B/C 问题样例合格修复为 3/4、1/4、4/4，最终对象通过为 7/8、5/8、8/8，完整任务为 7/8、4/8、6/8；未完成和失败不从统计中删除。该批次是自建合成模板留出，不是独立盲测。

3.7 Twine 历史外部依据

Twine 公开版本的配置解析错误曾令 traceback 携带敏感行进入 stderr。该单次外部任务固定源码和公开修复依据，模型提出三份候选：两份在执行前因格式/修改边界被拒，第三份通过七项受控条件。它是历史 Agent 依据，不是当前任意项目

自动修复成功、上游采纳或企业部署证明；官方升级仍是实际使用者应优先考虑的处理方式。



图 4 当前对象的实际复检记录 不调用模型

3.8 结果解释与适用边界

当前证据支持的结论是：在已适配、隔离、合成 Python 场景中，安全观察、必要业务检查、对象绑定和复检可以共同阻止“业务测试全通过但仍泄露”的误读，并把候选修改变成可复查材料。模型的作用是提出和调整候选，固定程序负责执行、权限和判决。未测量人工节省时间、总体准确率、跨机器部署或生产影响；模型文件系统边界和更多语言支持仍不属于本候选交付。

第四章 贡献与创新说明

4.1 证据反馈驱动的候选生成

困难是一次性补丁可能只隐藏标签而保留秘密。项目实现 agent_pilot/reliability.py 的受限工具会话，将脱敏失败回执提供给后续候选；h03 的两份候选和真实日志反例给出具体依据。它相对一次性生成多做的是“在当前副本上根据新证据再提出候选”，不是新模型算法，也不声称普遍优于固定程序。

4.2 程序实施的修改授权和联合验收

困难是模型建议不能拥有写入和批准权限，业务绿也不代表安全绿。项目实现 `agent_pilot/reliability.py` 、 `agent_pilot/judge.py` 、 `credproof_safety/project.py` 的路径/工具校验、安全观察、pytest 状态、业务行为和隔离收据检查。python-dotenv 重新引入缺陷的 117/117 业务通过而安全 FAIL，是该增量最直接的反例依据。它只覆盖声明的 Python 接口和检查矩阵。

4.3 对应对象的材料导出和重新验收

困难是报告可能对应旧副本，或历史轨迹缺失却仍被当作完整证据。项目实现 `agent_pilot/web.py` 的项目材料绑定和 `agent_pilot/bundle.py` 的完整性/复检；导出消费者固定、缺陷、无关三个副本的 0/1/0 退出结果与三份报告可复查。普通哈希和材料完整性提示不构成第三方认证。

4.4 角色边界与归属

人工确定授权和必要条件；固定程序生成初始证据、限制工具和修改、运行隔离并作 verdict；本地模型阅读允许材料、提出假设和候选。Qwen-Agent、Ollama、pytest、WSL/bubblewrap 及上游组件不是本项目原创。AI 辅助开发范围和参赛原创声明仍由参赛者、指导教师和组委会按实际规则确认。

第五章 总结

CredProof 把“可能泄露”推进到“在当前对象上能否接受这份修复，并且别人能否复查依据”。资料助手、python-dotenv 受控接入、h01/h03/h07 和历史 Twine 共同展示问题、动作、证据和边界。作品当前应作为已适配 Python 工具的防御性验证与受控修复原型使用；后续扩展到更多语言、更多系统调用和真实部署前，仍需新的适配、隔离和独立参与者体验。

来源与 AI 参与披露

公开组件和模型按许可证与来源归属列于 `docs/local-agent/reliability/source-attribution.md` 及本仓库来源索引。

ChatGPT/Codex 对方案、主要代码、调试、实验组织和文稿有实质辅助；本文件不代
签原创或 AI 使用声明，队伍需自行向指导教师和组委会确认。

参考文献

1. Qwen-Agent、Ollama、pytest 及 WSL/bubblewrap 官方文档，版本和下载核
验见仓库来源记录。

2. python-dotenv v1.2.2，提交 36004e0e34be7665ff2b11a8a4005144f76f176d，
BSD-3-Clause；本项目注入版仅用于受控安全验证。

3. Twine 公开修复依据与本项目固定复现实验，见
docs/external-scenario/twine/。

4.
experiments/local-agent-pilot/reliability/20260929t095000z-holdout8/compa
rison/，历史八例完整记录。